

ZAP Scanning Report

Generated with  ZAP on Thu 13 Aug 2026, at 09:12:25

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Contents

- [About This Report](#)
 - [Report Description](#)
 - [Report Parameters](#)
- [Summaries](#)
 - [Alert Counts by Risk and Confidence](#)
 - [Alert Counts by Site and Risk](#)
 - [Alert Counts by Alert Type](#)
- [Alerts](#)
 - [Risk=High, Confidence=Medium \(1\)](#)
 - [Risk=Medium, Confidence=High \(8\)](#)
 - [Risk=Medium, Confidence=Medium \(2\)](#)
 - [Risk=Low, Confidence=High \(3\)](#)

- [Risk=Low, Confidence=Medium \(7\)](#)
- [Risk=Low, Confidence=Low \(1\)](#)
- [Risk=Informational, Confidence=High \(3\)](#)
- [Risk=Informational, Confidence=Medium \(4\)](#)
- [Risk=Informational, Confidence=Low \(2\)](#)
- [Appendix](#)
 - [Alert Types](#)

About This Report

Report Description

Security scan on juice shop

Report Parameters

Contexts

No contexts were selected, so all contexts were included by default.

Sites

The following sites were included:

- <https://play.google.com>
- <https://www.google.com>
- <https://accounts.youtube.com>
- <https://fonts.gstatic.com>
- <https://www.gstatic.com>
- <https://accounts.google.com>

- <https://www.google-analytics.com>
- <https://owasp.org>
- <https://api.github.com>
- <https://avatars.githubusercontent.com>
- <https://collector.github.com>
- <https://camo.githubusercontent.com>
- <https://raw.githubusercontent.com>
- <https://github.githubassets.com>
- <https://github.com>
- <http://localhost:3000>

(If no sites were selected, all sites were included by default.)

An included site must also be within one of the included contexts for its data to be included in the report.

Risk levels

Included: [High](#), [Medium](#), [Low](#), [Informational](#)

Excluded: None

Confidence levels

Included: [User Confirmed](#), [High](#), [Medium](#), [Low](#)

Excluded: [User Confirmed](#), [High](#), [Medium](#), [Low](#), [False Positive](#)

Summaries

Alert Counts by Risk and Confidence

This table shows the number of alerts for each level of risk and confidence included in the report.

(The percentages in brackets represent the count as a percentage of the total number of alerts included in the report, rounded to one decimal place.)

		Confidence				
Risk		User Confirmed	High	Medium	Low	Total
	High	0 (0.0%)	0 (0.0%)	1 (3.2%)	0 (0.0%)	1 (3.2%)
	Medium	0 (0.0%)	8 (25.8%)	2 (6.5%)	0 (0.0%)	10 (32.3%)
	Low	0 (0.0%)	3 (9.7%)	7 (22.6%)	1 (3.2%)	11 (35.5%)
	Informational	0 (0.0%)	3 (9.7%)	4 (12.9%)	2 (6.5%)	9 (29.0%)
	1					
Total		0 (0.0%)	14 (45.2%)	14 (45.2%)	3 (9.7%)	31 (100%)

Alert Counts by Site and Risk

This table shows, for each site for which one or more alerts were raised, the number of alerts raised at each risk level.

Alerts with a confidence level of "False Positive" have been excluded from these counts.

(The numbers in brackets are the number of alerts raised for the site at or above that risk level.)

Risk

	Informational			
	High (= High)	Medium (>= Medium)	Low (>= Low)	(>= Informational)
https://play.google.com	0 (0)	0 (0)	1 (1)	2 (3)
https://www.gstatic.com	0 (0)	0 (0)	1 (1)	0 (1)
https://accounts.google.com	0 (0)	1 (1)	2 (3)	1 (4)
https://owasp.org	0 (0)	3 (3)	0 (3)	0 (3)
https://github.githubassets.com	0 (0)	0 (0)	1 (1)	2 (3)
https://github.com	0 (0)	2 (2)	2 (4)	2 (6)
http://localhost:3000	1 (1)	4 (5)	4 (9)	2 (11)

Alert Counts by Alert Type

This table shows the number of alerts of each alert type, together with the alert type's risk level.

(The percentages in brackets represent each count as a percentage, rounded to one decimal place, of the total number of alerts included in this report.)

Alert type	Risk	Count
Total		31

Alert type	Risk	Count
Off-site Redirect	High	1 (3.2%)
CSP: Failure to Define Directive with No Fallback	Medium	11 (35.5%)
CSP: Wildcard Directive	Medium	10 (32.3%)
CSP: script-src unsafe-eval	Medium	6 (19.4%)
CSP: script-src unsafe-inline	Medium	8 (25.8%)
CSP: style-src unsafe-inline	Medium	16 (51.6%)
Content Security Policy (CSP) Header Not Set	Medium	5 (16.1%)
Cross-Domain Misconfiguration	Medium	29 (93.5%)
Missing Anti-clickjacking Header	Medium	1 (3.2%)
Session ID in URL Rewrite	Medium	5 (16.1%)
Sub Resource Integrity Attribute Missing	Medium	7 (22.6%)
Application Error Disclosure	Low	1 (3.2%)
Total		31

Alert type	Risk	Count
CSP: Notices	Low	9 (29.0%)
Cookie No HttpOnly Flag	Low	1 (3.2%)
Cookie with SameSite Attribute None	Low	2 (6.5%)
Cookie without SameSite Attribute	Low	1 (3.2%)
Cross-Domain JavaScript Source File Inclusion	Low	7 (22.6%)
Private IP Disclosure	Low	3 (9.7%)
Server Leaks Version Information via "Server" HTTP Response Header Field	Low	6 (19.4%)
Strict-Transport-Security Header Not Set	Low	11 (35.5%)
Timestamp Disclosure - Unix	Low	16 (51.6%)
X-Content-Type-Options Header Missing	Low	10 (32.3%)
Content Security Policy (CSP) Report-Only Header Found	Informational	1 (3.2%)
Information Disclosure - Information in Browser localStorage	Informational	3 (9.7%)
Total		31

Alert type	Risk	Count
Information Disclosure - Information in Browser sessionStorage	Informational	2 (6.5%)
Information Disclosure - Sensitive Information in URL	Informational	1 (3.2%)
Information Disclosure - Suspicious Comments	Informational	5 (16.1%)
Loosely Scoped Cookie	Informational	2 (6.5%)
Modern Web Application	Informational	10 (32.3%)
Re-examine Cache-control Directives	Informational	10 (32.3%)
Retrieved from Cache	Informational	35 (112.9%)
Total		31

Alerts

Risk=High, Confidence=Medium (1)

<http://localhost:3000> (1)

Off-site Redirect (1)

► GET <http://localhost:3000/redirect?to=https://github.com/juice-shop/juice-shop>

Risk=Medium, Confidence=High (8)

<https://accounts.google.com> (1)

CSP: Wildcard Directive (1)

► GET https://accounts.google.com/o/oauth2/v2/auth?client_id=1005568560502-6hm16lef8oh46hr2d98vf2ohlnj4nfhq.apps.googleusercontent.com&response_type=token&scope=email&redirect_uri=https://local3000.owasp-juice.shop

<https://owasp.org> (3)

CSP: Failure to Define Directive with No Fallback (1)

► GET <https://owasp.org/slack/invite>

CSP: script-src unsafe-eval (1)

► GET <https://owasp.org/slack/invite>

CSP: script-src unsafe-inline (1)

► GET <https://owasp.org/slack/invite>

<https://github.com> (2)

CSP: style-src unsafe-inline (1)

► GET <https://github.com/juice-shop/juice-shop>

Sub Resource Integrity Attribute Missing (1)

► GET <https://github.com/juice-shop/juice-shop>

<http://localhost:3000> (2)

Content Security Policy (CSP) Header Not Set (1)

► GET <http://localhost:3000>

Session ID in URL Rewrite (1)

► GET <http://localhost:3000/socket.io/?EIO=4&transport=websocket&sid=3oQJ0KLnr0S32dEvAAAC>

Risk=Medium, Confidence=Medium (2)

<http://localhost:3000> (2)

Cross-Domain Misconfiguration (1)

► GET http://localhost:3000/assets/public/favicon_js.ico

Missing Anti-clickjacking Header (1)

► POST http://localhost:3000/socket.io/?EIO=4&transport=polling&t=P_xkbFM&sid=3oQJ0KLnr0S32dEvAAAC

Risk=Low, Confidence=High (3)

<https://www.gstatic.com> (1)

Strict-Transport-Security Header Not Set (1)

► GET
https://www.gstatic.com/images/branding/googleg_gradient/svg/googleg_gradient_standard_24px.svg

<https://accounts.google.com> (1)

CSP: Notices (1)

► GET https://accounts.google.com/o/oauth2/v2/auth?client_id=1005568560502-6hm16lef8oh46hr2d98vf2ohlnj4nfhq.apps.googleusercontent.com&response_type=token&scope=email&redirect_uri=https://local3000.owasp-juice.shop

<https://github.githubassets.com> (1)

Server Leaks Version Information via "Server" HTTP Response Header Field (1)

► GET <https://github.githubassets.com/assets/primer-primitives-9f1db623a2d85734.css>

Risk=Low, Confidence=Medium (7)

<https://play.google.com> (1)

Cookie with SameSite Attribute None (1)

► POST <https://play.google.com/log?hasfast=true&authuser=0&format=json>

<https://accounts.google.com> (1)

Cookie without SameSite Attribute (1)

► GET https://accounts.google.com/o/oauth2/v2/auth?client_id=1005568560502-6hm16lef8oh46hr2d98vf2ohlnj4nfhq.apps.googleusercontent.com&response_type=token&scope=email&redirect_uri=https://local3000.owasp-juice.shop

<https://github.com> (2)

[Cookie No HttpOnly Flag \(1\)](#)

► GET <https://github.com/juice-shop/juice-shop>

[Cross-Domain JavaScript Source File Inclusion \(1\)](#)

► GET <https://github.com/juice-shop/juice-shop>

<http://localhost:3000> (3)

[Application Error Disclosure \(1\)](#)

► POST <http://localhost:3000/api/Feedbacks/>

[Private IP Disclosure \(1\)](#)

► GET <http://localhost:3000/rest/admin/application-configuration>

[X-Content-Type-Options Header Missing \(1\)](#)

► GET http://localhost:3000/socket.io/?EI0=4&transport=polling&t=P_xkbDE

Risk=Low, Confidence=Low (1)

<http://localhost:3000> (1)

Timestamp Disclosure - Unix (1)

► GET http://localhost:3000/styles.css

Risk=Informational, Confidence=High (3)

<https://accounts.google.com> (1)

Content Security Policy (CSP) Report-Only Header Found (1)

► GET https://accounts.google.com/v3/signin/identifier?
opparams=%253F&dsh=S-
184149926%3A1786635301014081&client_id=1005568560502-
6hm16lef8oh46hr2d98vf2ohl nj4nfhq.apps.googleusercontent.com&o2v=2
&redirect_uri=https%3A%2F%2Flocal3000.owasp-
juice.shop&response_type=token&scope=email&service=lso&flowName=G
eneralOAuthFlow&continue=https%3A%2F%2Faccounts.google.com%2Fsign
in%2Foauth%2Fconsent%3Fauthuser%3Dunknown%26part%3DAJi8hAMAM_qU5I
VWgidGZ5o7JtoTbdIb-
xhNwJ6RiAIR5GBd8T51EsaWSwLrXiRWhQQL9tLscN09GwgYRNktXcQ9T2dSLp_oM8
5k7-
YpZdFJ06BrgJYo7BIInnA4G2w_zbbc_d5UcstFfRIGfhJq4c_mfyXiPvWxnPfyuVuK
j-cDHI-N1SRme9y2fbDZRhLDT3zIGlqYa-
w3HzhytB_5KC09XHL1rnPsUSTHiT4H5pKuQpod4ufA6mjiqKxVZSyHiF_lxfkHJv0
MoO44eezGhUIy_wonJyoFWzEV2eMuOxQouUZhQiZ5C3Qj8xZ2_I1Lszlbe2NsaJco
lW6ho-
R9BxBq2NpJIdII6pwV2qYgj4oBSDRr3thhn4YDIYldR03adecce30tUt6Mj0Lbtg5
rveWJzG4lMldHOQ0hmFEW5X-
JCjiY4rXhLJbW4xfb00t5kiLdvVGzqZGx6Qg36L7h0gIya6NG8xyL0K9Ddt48aEAh
diN7W5Yik8C4%26flowName%3DGeneralOAuthFlow%26as%3DS-
184149926%253A1786635301014081%26client_id%3D1005568560502-
6hm16lef8oh46hr2d98vf2ohl nj4nfhq.apps.googleusercontent.com%26req
uestPath%3D%252Fsignin%252Foauth%252Fconsent%23&app_domain=https%
3A%2F%2Flocal3000.owasp-
juice.shop&rart=ANGoxcd3bYU6QpsSPHWfFD_rUnzKSyP97m8yUAF2YhidfjYrR
Te3_jIGMaAlS0shbnCWi_4TA0_fqddowD470C6lJHRecVGktPxCUikASAE05uW0I
J-_e8

<https://github.com> (1)

Information Disclosure - Information in Browser localStorage (1)

► GET <https://github.com/juice-shop/juice-shop>

<http://localhost:3000> (1)

Information Disclosure - Information in Browser sessionStorage (1)

► GET <http://localhost:3000/#/basket>

Risk=Informational, Confidence=Medium (4)

<https://play.google.com> (1)

Information Disclosure - Sensitive Information in URL (1)

► POST [https://play.google.com/log?
hasfast=true&authuser=0&format=json](https://play.google.com/log?hasfast=true&authuser=0&format=json)

<https://github.githubassets.com> (2)

Information Disclosure - Suspicious Comments (1)

► GET [https://github.githubassets.com/assets/chunk-lazy-element-
select-panel-41aa0dbd0a85c593.js](https://github.githubassets.com/assets/chunk-lazy-element-select-panel-41aa0dbd0a85c593.js)

Retrieved from Cache (1)

► GET <https://github.githubassets.com/assets/primer-primitives-9f1db623a2d85734.css>

<http://localhost:3000> (1)

Modern Web Application (1)

► GET <http://localhost:3000>

Risk=Informational, Confidence=Low (2)

<https://play.google.com> (1)

Loosely Scoped Cookie (1)

► POST <https://play.google.com/log?hasfast=true&authuser=0&format=json>

<https://github.com> (1)

Re-examine Cache-control Directives (1)

► GET <https://github.com/juice-shop/juice-shop>

Appendix

Alert Types

This section contains additional information on the types of alerts in the report.

Off-site Redirect

Source	raised by a passive scanner (Off-site Redirect)
CWE ID	601
WASC ID	38
Reference	▪ https://cheatsheetseries.owasp.org/cheatsheets/Unvalidated_Redirects_and_Forwards_Cheat_Sheet.html ▪ https://cwe.mitre.org/data/definitions/601.html

CSP: Failure to Define Directive with No Fallback

Source	raised by a passive scanner (CSP)
CWE ID	693
WASC ID	15
Reference	▪ https://www.w3.org/TR/CSP/ ▪ https://caniuse.com/#search=content+security+policy ▪ https://content-security-policy.com/ ▪ https://github.com/HtmlUnit/htmlunit-csp ▪ https://web.dev/articles/csp#resource-options

CSP: Wildcard Directive

Source	raised by a passive scanner (CSP)
CWE ID	693
WASC ID	15
Reference	▪ https://www.w3.org/TR/CSP/ ▪ https://caniuse.com/#search=content+security+policy ▪ https://content-security-policy.com/ ▪ https://github.com/HtmlUnit/htmlunit-csp ▪ https://web.dev/articles/csp#resource-options

CSP: script-src unsafe-eval

Source	raised by a passive scanner (CSP)
CWE ID	693
WASC ID	15
Reference	▪ https://www.w3.org/TR/CSP/ ▪ https://caniuse.com/#search=content+security+policy ▪ https://content-security-policy.com/ ▪ https://github.com/HtmlUnit/htmlunit-csp ▪ https://web.dev/articles/csp#resource-options

CSP: script-src unsafe-inline

Source	raised by a passive scanner (CSP)
CWE ID	693
WASC ID	15
Reference	▪ https://www.w3.org/TR/CSP/ ▪ https://caniuse.com/#search=content+security+policy ▪ https://content-security-policy.com/ ▪ https://github.com/HtmlUnit/htmlunit-csp ▪ https://web.dev/articles/csp#resource-options

CSP: style-src unsafe-inline

Source	raised by a passive scanner (CSP)
CWE ID	693
WASC ID	15
Reference	▪ https://www.w3.org/TR/CSP/ ▪ https://caniuse.com/#search=content+security+policy ▪ https://content-security-policy.com/ ▪ https://github.com/HtmlUnit/htmlunit-csp ▪ https://web.dev/articles/csp#resource-options

Content Security Policy (CSP) Header Not Set

Source	raised by a passive scanner (Content Security Policy (CSP) Header Not Set)
CWE ID	693
WASC ID	15
Reference	▪ https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP ▪ https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html ▪ https://www.w3.org/TR/CSP/ ▪ https://w3c.github.io/webappsec-csp/ ▪ https://web.dev/articles/csp ▪ https://caniuse.com/#feat=contentsecuritypolicy ▪ https://content-security-policy.com/

Cross-Domain Misconfiguration

Source	raised by a passive scanner (Cross-Domain Misconfiguration)
CWE ID	264
WASC ID	14
Reference	▪ https://vulncat.fortify.com/en/detail?category=HTML5&subcategory=Overly%20Permissive%20CORS%20Policy

Missing Anti-clickjacking Header

Source	raised by a passive scanner (Anti-clickjacking Header)
CWE ID	1021
WASC ID	15
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options

Session ID in URL Rewrite

Source	raised by a passive scanner (Session ID in URL Rewrite)
CWE ID	598
WASC ID	13
Reference	https://seclists.org/webappsec/2002/q4/111

Sub Resource Integrity Attribute Missing

Source	raised by a passive scanner (Sub Resource Integrity Attribute Missing)
CWE ID	345
WASC ID	15
Reference	https://developer.mozilla.org/en-US/docs/Web/Security/Defenses/Subresource Integrity

Application Error Disclosure

Source raised by a passive scanner ([Application Error Disclosure](#))

CWE ID [550](#)

WASC ID 13

CSP: Notices

Source raised by a passive scanner ([CSP](#))

CWE ID [693](#)

WASC ID 15

Reference

- <https://www.w3.org/TR/CSP/>
- <https://caniuse.com/#search=content+security+policy>
- <https://content-security-policy.com/>
- <https://github.com/HtmlUnit/htmlunit-csp>
- <https://web.dev/articles/csp#resource-options>

Cookie No HttpOnly Flag

Source raised by a passive scanner ([Cookie No HttpOnly Flag](#))

CWE ID [1004](#)

WASC ID 13

Reference

- <https://owasp.org/www-community/HttpOnly>

Cookie with SameSite Attribute None

Source raised by a passive scanner ([Cookie without SameSite Attribute](#))

CWE ID [1275](#)

WASC ID 13

Reference ▪ <https://datatracker.ietf.org/doc/html/draft-ietf-httpbis-cookie-same-site>

Cookie without SameSite Attribute

Source raised by a passive scanner ([Cookie without SameSite Attribute](#))

CWE ID [1275](#)

WASC ID 13

Reference ▪ <https://datatracker.ietf.org/doc/html/draft-ietf-httpbis-cookie-same-site>

Cross-Domain JavaScript Source File Inclusion

Source raised by a passive scanner ([Cross-Domain JavaScript Source File Inclusion](#))

CWE ID [829](#)

WASC ID 15

Private IP Disclosure

Source	raised by a passive scanner (Private IP Disclosure)
CWE ID	497
WASC ID	13
Reference	▪ https://datatracker.ietf.org/doc/html/rfc1918

Server Leaks Version Information via "Server" HTTP Response Header Field

Source	raised by a passive scanner (HTTP Server Response Header)
CWE ID	497
WASC ID	13
Reference	▪ https://httpd.apache.org/docs/current/mod/core.html#servertokens ▪ https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552(v=pandp.10) ▪ https://www.troyhunt.com/shhh-dont-let-your-response-headers/

Strict-Transport-Security Header Not Set

Source	raised by a passive scanner (Strict-Transport-Security Header)
CWE ID	319
WASC ID	15

Reference

- https://cheatsheetseries.owasp.org/cheatsheets/HTTP_Strict_Transport_Security_Cheat_Sheet.html
- <https://owasp.org/www-community/Security-Headers>
- https://en.wikipedia.org/wiki/HTTP_Strict_Transport_Security
- <https://caniuse.com/stricttransportsecurity>
- <https://datatracker.ietf.org/doc/html/rfc6797>

Timestamp Disclosure - Unix

Source raised by a passive scanner ([Timestamp Disclosure](#))

CWE ID [497](#)

WASC ID 13

Reference ▪ <https://cwe.mitre.org/data/definitions/200.html>

X-Content-Type-Options Header Missing

Source raised by a passive scanner ([X-Content-Type-Options Header Missing](#))

CWE ID [693](#)

WASC ID 15

Reference

- [https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941\(v=vs.85\)](https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85))
- <https://owasp.org/www-community/Security-Headers>

Content Security Policy (CSP) Report-Only Header Found

Source raised by a passive scanner ([Content Security Policy \(CSP\) Header Not Set](#))

CWE ID [693](#)

WASC ID 15

Reference

- <https://www.w3.org/TR/CSP2/>
- <https://w3c.github.io/webappsec-csp/>
- <https://caniuse.com/#feat=contentsecuritypolicy>
- <https://content-security-policy.com/>

Information Disclosure - Information in Browser localStorage

Source raised by a passive scanner ([plugin ID: 120000](#))

CWE ID [359](#)

WASC ID 13

Information Disclosure - Information in Browser sessionStorage

Source raised by a passive scanner ([plugin ID: 120000](#))

CWE ID [359](#)

WASC ID 13

Information Disclosure - Sensitive Information in URL

Source raised by a passive scanner ([Information Disclosure - Sensitive Information in URL](#))

CWE ID [598](#)

WASC ID 13

Information Disclosure - Suspicious Comments

Source raised by a passive scanner ([Information Disclosure - Suspicious Comments](#))

CWE ID [615](#)

WASC ID 13

Loosely Scoped Cookie

Source raised by a passive scanner ([Loosely Scoped Cookie](#))

CWE ID [565](#)

WASC ID 15

Reference

- <https://datatracker.ietf.org/doc/html/rfc6265#section-4.1>
- <https://owasp.org/www-project-web-security-testing-guide/v41/4->

[Web_Application_Security_Testing/06-Session_Management_Testing/02-Testing_for_Cookies_Attributes.html](#)

- <https://code.google.com/archive/p/browsersec/wikis/Part2.wiki>

Modern Web Application

Source raised by a passive scanner ([Modern Web Application](#))

Re-examine Cache-control Directives

Source raised by a passive scanner ([Re-examine Cache-control Directives](#))

CWE ID [525](#)

WASC ID 13

- Reference**
- https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html#web-content-caching
 - <https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cache-Control>
 - <https://grayduck.mn/2021/09/13/cache-control-recommendations/>

Retrieved from Cache

Source	raised by a passive scanner (Retrieved from Cache)
CWE ID	525
Reference	▪ https://datatracker.ietf.org/doc/html/rfc7234 ▪ https://datatracker.ietf.org/doc/html/rfc7231 ▪ https://www.rfc-editor.org/rfc/rfc9110.html